Part 2: Vulnerability Analysis

By Molapo Manuel

Vulnerability: Missing Security Headers.

Description:
The web server (Apache) was found to be missing several critical security headers, including:

- Content Security Policy (CSP)
- X-Frame-Options
- Strict-Transport-Security (HSTS)
- Referrer-policy
- Permission policy

Evidence:
Nikto scan output (see Figure 1.1) clearly indicates that these headers are absent.

```
+ Your Nikto installation is out of date.
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Platform:           Linux/Unix
+ Start Time:         2026-03-30 23:24:15 (GMT2)
---------------------------------------------------------------------------
+ Server: Apache/2.4.66 (Debian)
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /DVWA/: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /DVWA/: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /DVWA/: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /DVWA/: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /DVWA/: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [750500] /DVWA/config/: Directory indexing found.
```

Impact / Risk:

- Missing CSP increases the risk of Cross-Site Scripting (XSS) attacks.
- Absence of HSTS may allow Man-in-the-Middle (MITM) attacks over HTTP.
- Lack of X-Frame-Options allows clickjacking attacks.

Remediation / Recommendation:

- Configure Apache to include the missing security headers:

Vulnerability:Direrectory indexing

Description:
Directory indexing is enabled on several directories of the DVWA web application. This allows anyone accessing these directories to **v**iew the list of files and subdirectories. Sensitive files like configuration files, test scripts, or source code may be exposed.

Evidence

Nikto scan. Figure 1.2

- Screenshot (Figure 1.2) shows /config/, /database/, and /tests/ directories are listable in the browser.
- Tools like Dirb, Gobuster, and ffuf confirmed these directories are accessible.

Impact / Risk:

- Exposure of sensitive files can lead to information disclosure, giving attackers details about the web application structure.
- Attackers may use this information to plan targeted attacks such as SQL injection, code execution, or credential theft.
- High severity for penetration testing purpose

Remediation / Recommendation:

- Disable directory listing on the web server by modifying Apache configuration:
- Restart Apache after changes:

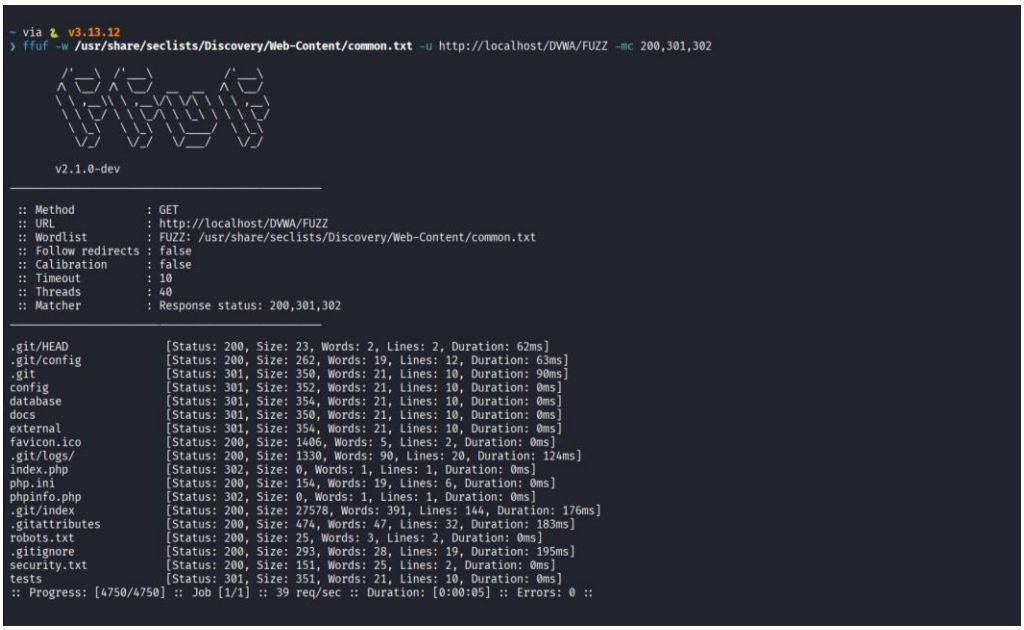
Vulnerability:exposed.git repository

Description:
The. git directory of the DVWA application is publicly accessible. This directory contains the version control history, configuration files, and potentially sensitive source code. Attackers can download and reconstruct the repository, exposing application logic, credentials, or hidden endpoints.

Evidence:

- Screenshot (Figure 1.3) and screenshot (Figure 1.4) show the .git/config file accessible via browser or enumeration tools.
- ffuf and Gobuster confirmed the presence of. git and its files.

Figure1.3 ffuf tool



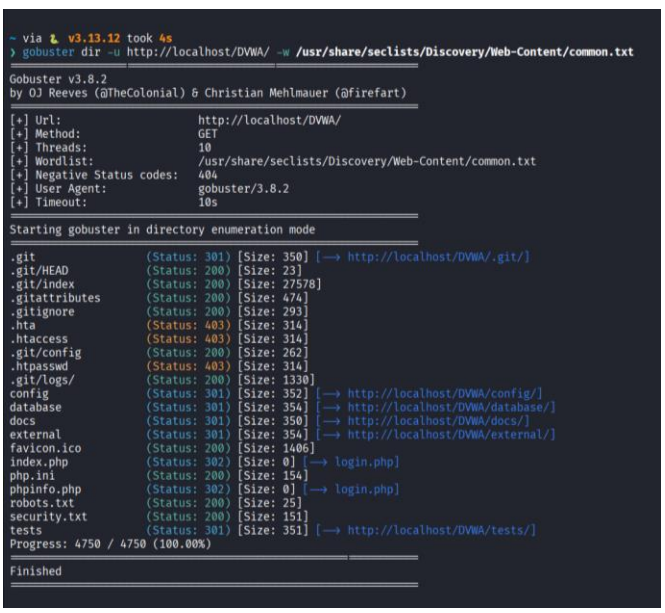
```
~ via 🐍 v3.13.12
❯ ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt -u http://localhost/DVWA/FUZZ -mc 200,301,302

        v2.1.0-dev

 :: Method           : GET
 :: URL              : http://localhost/DVWA/FUZZ
 :: Wordlist         : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200,301,302

.git/HEAD               [Status: 200, Size: 23, Words: 2, Lines: 2, Duration: 62ms]
.git/config             [Status: 200, Size: 262, Words: 19, Lines: 12, Duration: 63ms]
.git                    [Status: 301, Size: 350, Words: 21, Lines: 10, Duration: 90ms]
config                  [Status: 301, Size: 352, Words: 21, Lines: 10, Duration: 0ms]
database                [Status: 301, Size: 354, Words: 21, Lines: 10, Duration: 0ms]
docs                    [Status: 301, Size: 350, Words: 21, Lines: 10, Duration: 0ms]
external                [Status: 301, Size: 354, Words: 21, Lines: 10, Duration: 0ms]
favicon.ico             [Status: 200, Size: 1406, Words: 5, Lines: 2, Duration: 0ms]
.git/logs/              [Status: 200, Size: 1330, Words: 90, Lines: 20, Duration: 124ms]
index.php               [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 0ms]
php.ini                 [Status: 200, Size: 154, Words: 19, Lines: 6, Duration: 0ms]
phpinfo.php             [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 0ms]
.git/index              [Status: 200, Size: 27578, Words: 391, Lines: 144, Duration: 176ms]
.gitattributes          [Status: 200, Size: 474, Words: 47, Lines: 32, Duration: 183ms]
robots.txt              [Status: 200, Size: 25, Words: 3, Lines: 2, Duration: 0ms]
.gitignore              [Status: 200, Size: 293, Words: 28, Lines: 19, Duration: 195ms]
security.txt            [Status: 200, Size: 151, Words: 25, Lines: 2, Duration: 0ms]
tests                   [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 0ms]
:: Progress: [4750/4750] :: Job [1/1] :: 39 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

Figure 1.4 gobuster tool



```
~ via 🐍 v3.13.12 took 4s
❯ gobuster dir -u http://localhost/DVWA/ -w /usr/share/seclists/Discovery/Web-Content/common.txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
[+] Url:                     http://localhost/DVWA/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
Starting gobuster in directory enumeration mode
.git                 (Status: 301) [Size: 350] [--> http://localhost/DVWA/.git/]
.git/HEAD            (Status: 200) [Size: 23]
.git/index           (Status: 200) [Size: 27578]
.gitattributes       (Status: 200) [Size: 474]
.gitignore           (Status: 200) [Size: 293]
.hta                 (Status: 403) [Size: 314]
.htaccess            (Status: 403) [Size: 314]
.git/config          (Status: 200) [Size: 262]
.htpasswd            (Status: 403) [Size: 314]
.git/logs/           (Status: 200) [Size: 1330]
config               (Status: 301) [Size: 352] [--> http://localhost/DVWA/config/]
database             (Status: 301) [Size: 354] [--> http://localhost/DVWA/database/]
docs                 (Status: 301) [Size: 350] [--> http://localhost/DVWA/docs/]
external             (Status: 301) [Size: 354] [--> http://localhost/DVWA/external/]
favicon.ico          (Status: 200) [Size: 1406]
index.php            (Status: 302) [Size: 0] [--> login.php]
php.ini              (Status: 200) [Size: 154]
phpinfo.php          (Status: 302) [Size: 0] [--> login.php]
robots.txt           (Status: 200) [Size: 25]
security.txt         (Status: 200) [Size: 151]
tests                (Status: 301) [Size: 351] [--> http://localhost/DVWA/tests/]
Progress: 4750 / 4750 (100.00%)
Finished
```

Impact / Risk:

- High severity.

- Source code exposure allows attackers to discover hardcoded credentials, hidden functions, or other vulnerabilities.
- Can accelerate exploitation of other weaknesses in the application.

Remediation / Recommendation:

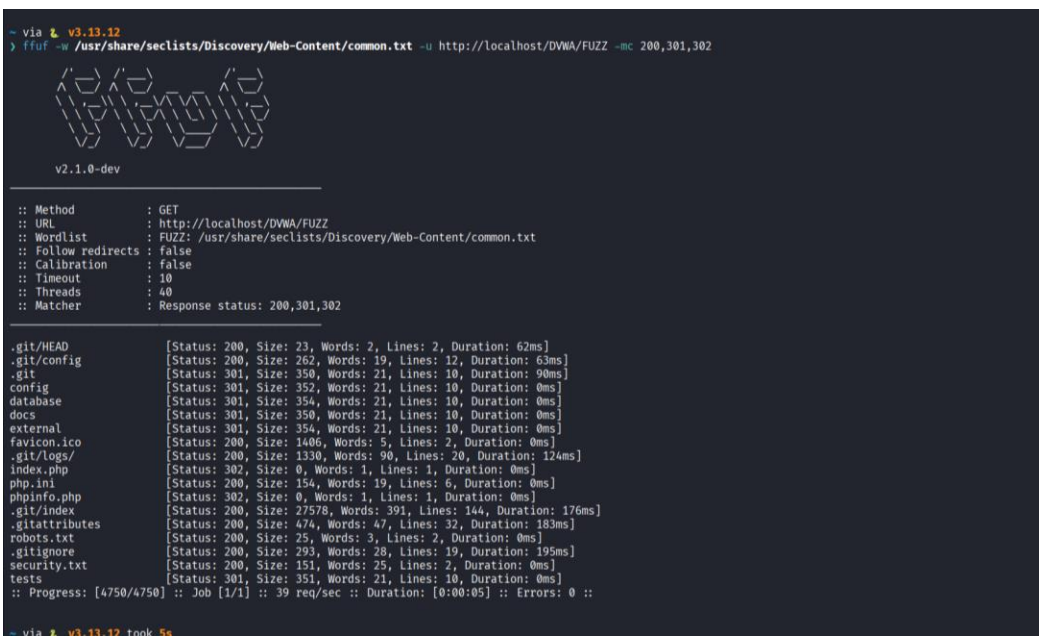
- Restrict access to. git directories in the web server:
- Remove. git directory from production web root if not needed.
- Restart Apache to apply changes:

Vulnerability: Sensitive Files Exposed

Description:
These configuration files are publicly accessible. php.ini and phpinfo.php reveal server configuration, PHP settings, and potentially sensitive paths or environment variables.

Evidence:

- Screenshot (Figure 1.5) shows files accessible in the browser.



Impact / Risk:

- High severity.
- Exposes system configuration details that attackers can use to plan targeted attacks or exploit known misconfigurations.

Remediation / Recommendation:

- Restrict access to sensitive files via .htaccess or Apache configuration
- Move configuration files outside the web root if possible.

Vulnerability: Multiple Open Ports

Description:
Several services are running and listening on multiple ports, increasing the attack surface.

Evidence:

- Nmap scan output (Figure 1.6) confirms open ports and running services.

```
~ via 🐍 v3.13.12
❯ nmap -sS -sV -p- localhost
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 23:08 +0200
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000030s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 65529 closed tcp ports (reset)
PORT     STATE SERVICE  VERSION
80/tcp   open  http     Apache httpd 2.4.66 ((Debian))
3306/tcp open  mysql?
8000/tcp open  http     Splunkd httpd
8065/tcp open  http     CherryPy wsgiserver
8089/tcp open  ssl/http Splunkd httpd
8191/tcp open  mongodb  MongoDB 3.6 after 3.6.3, or 3.7.3 or later
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3306-TCP:V=7.98%I=7%D=3/30%Time=69CAE65A%P=x86_64-pc-linux-gnu%r(NU
SF:LL,64,"`\0\0\0\n11\.8\.6-MariaDB-4\x20from\x20Debian\0J\0\0\0\[V}2~H\)4
SF:\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0\0=\0\0\0i4f\)5nKiSD8,\0mysql_na
SF:tive_password\0")%r(GenericLines,9C,"`\0\0\0\n11\.8\.6-MariaDB-4\x20fro
SF:m\x20Debian\0J\0\0\0\[V}2~H\)4\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0\0
SF:=\0\0\0i4f\)5nKiSD8,\0mysql_native_password\x004\0\0\x01\xffj\x04#HY000
SF:Proxy\x20header\x20is\x20not\x20accepted\x20from\x20127\.0\.0\.1")%r(LD
SF:APBindReq,64,"`\0\0\0\n11\.8\.6-MariaDB-4\x20from\x20Debian\0\[\0\0\0E3
SF:lG\]~%8\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0\0=\0\0\0\*gJzJBM:xrQ~\0m
SF:ysql_native_password\0")%r(afp,64,"`\0\0\0\n11\.8\.6-MariaDB-4\x20from\
SF:x20Debian\0e\0\0\0Bo\)yKGc\?\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0\0=\
SF:0\0\0QV<j\"f\[xi\)\+:\0mysql_native_password\0");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.44 seconds
```

Impact / Risk:

- Medium severity.
- Each open port represents a potential entry point for attackers. Services like MySQL or MongoDB could be attacked if misconfigured or if default credentials exist.

Remediation / Recommendation:

- Close unnecessary ports or restrict access using firewall rules:

Vulnerability: Outdated / Identified Server Version

Description:
The server version is publicly exposed via HTTP headers. Attackers can look for known vulnerabilities in this version.

Evidence:

- Screenshot (Figure 1.7) shows the Apache version in response headers.

```
~ via 🐍 v3.13.12
❯ curl http://localhost/DVWA/ -v
* Host localhost:80 was resolved.
* IPv6: ::1
* IPv4: 127.0.0.1
*   Trying [::1]:80...
* Established connection to localhost (::1 port 80) from ::1 port 35886
* using HTTP/1.x
> GET /DVWA/ HTTP/1.1
> Host: localhost
> User-Agent: curl/8.18.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 302 Found
< Date: Mon, 30 Mar 2026 20:16:33 GMT
< Server: Apache/2.4.66 (Debian)
< Set-Cookie: security=impossible; path=/; HttpOnly
< Set-Cookie: PHPSESSID=5f9efdaceefd389f29556104a50a1f4f; expires=Tue, 31 Mar 2026 20:16:33 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate
< Pragma: no-cache
< Set-Cookie: PHPSESSID=ec4effe9e5af9d52b3ba8d7a0a163000; expires=Tue, 31 Mar 2026 20:16:33 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict
< Location: login.php
< Content-Length: 0
< Content-Type: text/html; charset=UTF-8
<
* Connection #0 to host localhost:80 left intact

~ via 🐍 v3.13.12
```

Impact / Risk:

- Medium severity.
- Version disclosure can allow attackers to target known CVEs for Apache 2.4.66.

Remediation / Recommendation:

- Hide server version in Apache configuration.
- Keep Apache updated with security patches.

Vulnerability: Username Enumeration

Description:
Username enumeration occurs when a web application reveals whether a username exists based on login responses or error messages. This is often due to lack of uniform error messages and no restrictions on login attempts. Attackers can leverage this to guess valid usernames and perform brute-force or credential-stuffing attacks.

Evidence

During testing on the DVWA login page, multiple usernames and passwords were attempted. The application did not block repeated login attempts and continued to provide feedback on the validity of usernames. This behavior confirms that the application is vulnerable to username enumeration and brute-force attacks.

- Screenshot (Figure 1.8) shows the response for invalid usernames and passwords.
- Multiple attempts with different username/password combinations were performed, all receiving a “Login failed” response without any account lockout or rate limiting.

Summary

Vulnerability	Location	Evidence -figure	risks
Missing Security Headers	Web Server (Apache)	**1.1**	Medium – Increased risk of XSS, MITM
Directory indexing	/config/, /database/, /tests	**1.2**	High – Sensitive file exposure
Exposed. git Repository	git	**1.3** **1.4**	High – Source code disclosure
Sensitive Files Exposed	php.ini, phpinfo.php	**1.5**	High – System configuration leakage
Multiple Open Ports	80, 3306, 8089, 8191	**1.6**	Medium – Expanded attack surface
Outdated/Identified Server Version	Apache 2.4.66 (Debian	**1.7**	Medium – Potential known exploits

Username Enumeration	Login Page	**1.8**	Low-Medium – Enables targeted attacks